SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Emirhan Uzen · No: 230541086** Grup **4B-Gündüz** Tarih **06.11.2026**

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	CNC-D800 Component X (ARM PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, etkiliyor. Bileşen VAR: SBOM'da ARM PLC firmware kütüphanesi kayıtlı. Sürüm ETKİLENİYOR: makinede 2.4 kurulu. Açık ULAŞILABİLİR: internete açık uzak servis modülü, bulut telemetri ve DXF/DWG yükleme yolu üzerinden.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam. Önce uzak servis modülünü kapatır, internet/bulut bağlantısını keserim; makine yerelde çalışır. Anormal eksen/taş hareketi, kapak kilidi ya da acil stop hatası görürsem makineyi hemen güvenli duruşa alırım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. ABM'den imzalı yama alınır, hash doğrulanır. Test yeri: yedek PLC / TwinCAT test PC'si; yoksa planlı duruşta, tam yedek + geri dönüş planıyla. Örnek testereyle bileme programı denenir.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama notları ve ABM'nin etki analizi incelenir: acil stop, kapak kilidi, eksen hız/limit fonksiyonlarına dokunuyor mu? Emniyet ayrı safety rölesindeyse etkilenmez; aynı PLC'deyse yamadan sonra acil stop + kapak kilidi testleri tekrarlanır, kayda geçer.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak servis modülü varsayılan KAPALI; sadece VPN + MFA + kişisel hesapla ve oturum kaydıyla açılır. Makine ayrı VLAN/firewall arkasında; bulut telemetri yalnızca dışa doğru. DXF/DWG dosyaları taranır, hash/imza kontrolü yapılır; USB kilitli; loglar izlenir. Kalan risk yazılı olarak kabul edilir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · CNC-D800 · DAIRE TESTERE BILEME MAKINESI

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Emirhan Uzen · No: 230541086	Grup	4B-Gündüz	Tarih	06.11.2026

Senaryo: Saat **10:15**. CNC-D800'ün servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC/TwinCAT konfigürasyonu değişmiş olabilir; **kapak kilidi ve acil stop parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Arayacağım kişiler: bakım/otomasyon sorumlusu, OT-BT güvenlik sorumlusu, üretim müdürü; sonra ABM servisi. 1) Makineyi kontrollü durdurur, güvenli duruşa alır, personeli uzaklaştırırım. 2) Uzak servis modülünü ve ağ kablosunu fiziksel olarak ayırırım; KAPATMAM, resetlemem. 3) Olay kaydı açarım: saat, gözlem, ekran fotoğrafı.

2. **İlk 2 saat:** Emniyet güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Kapak kilidi, acil stop ve eksen durdurmayı kontrollü test ederim. TwinCAT/PLC parametreleri ve G-code'lar onaylı yedekle (hash) karşılaştırılır; fark varsa makine kilitli kalır. Kanıt: PLC/TwinCAT logları, uzak erişim + firewall kayıtları, bulut telemetri (akım/tork/sıcaklık), proje + parametre imajı. Kapatılan: ele geçirilen servis hesabı, aynı parolalı hesaplar, açık oturumlar.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Bildirim yükümlülüğü üretici ABM'de; biz ABM'ye bildiririz. Hazır olmalı: tespit zamanı, ürün (CNC-D800, seri no, PLC/TwinCAT sürümü), aktif istismar şüphesi, ilk etki (insan zararı var/yok), alınan önlemler, irtibat kişisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (açık uzak servis modülü, zayıf parola?): OT güvenlik + ABM servis. Etki (değişen parametre/G-code, hatalı bilenen testereler, emniyet etkisi): üretim + kalite. Önlem (MFA, kapalı uzak erişim, yama): bakım + BT. Bildirim koordinasyonu: olay sorumlusu + ABM.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Uzak erişim/VPN ve giriş logları, PLC/TwinCAT olay-alarm logları, parametre + G-code değişiklik geçmişi, DXF/DWG yükleme kayıtları, firewall/ağ logları, bulut telemetri kayıtları, olay öncesi/sonrası yedekler, emniyet test sonuçları, olay günlüğü. Zaman damgalı ve hash'li saklanır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · CNC-D800 · DAIRE TESTERE BILEME MAKINESI

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad **Emirhan Uzen · No: 230541086** Grup **4B-Gündüz** Tarih **06.11.2026**

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: CNC-D800'e YZ'li görsel diş kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?
   Uyarlama: bilemeden sonra dişleri kontrol eden YZ kamera. Kusurlu (yanlış açılı/kırık dişli) testere OK aldıysa müşteriye gider, kullanımda kırılma riski doğar. YZ tek karar verici olmaz: Ø büyük testerelerde insan onayı, diğerlerinde numune kontrolü; hata oranı izlenir, eşik aşılırsa makine durur. Kapak kilidi + acil stop YZ'den bağımsızdır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?
   Nasıl fark edilir: donmuş/tekrar eden kare, aşırı karanlık ya da parlak görüntü, tutarsız zaman damgası, kamera heartbeat'i yok, referans kalibrasyon parçası tanınmıyor. Şüpheli girdide: OK verilmez, testere RED/karantinaya alınır, operatöre alarm gider, manuel kontrole geçilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?
   Eşik test verisiyle belirlenir, ör. %95; sadece yetkili kişi değiştirir, kayda geçer. Altında otomatik OK yok, operatöre sorulur (human override). Sıklaşırsa hız düşürülür veya manuel ölçüme (fallback) geçilir; durum izlenir (monitoring).

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	**Monitoring + human override: numune insan kontrolü, hata oranı izlenir; eşik aşılırsa makine durur.**
Girdi manipüle edildi	**Fail-safe: şüpheli görüntüde OK yok; testere karantinaya alınır, alarm, manuel kontrol.**
Confidence düştü	**Confidence threshold + fallback: %95 altı insana sorulur; sıklaşırsa manuel ölçüme geçilir.**

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.